Indian banking phishing & UPI fraud

The CERT-In documented campaign of August 2021

The CERT-In documented campaign of August 2021 demonstrates how a convincing banking message can turn customer trust into an attack path. This case study examines internet-banking impersonation, stolen credentials and OTP interception, then considers the lessons for UPI safety. It separates documented campaign details from analytical interpretation and proposed controls. The primary evidence is CERT-In advisory CICA-2021-2948, published on 10 August 2021. Supporting guidance comes from RBI, NPCI and India’s national cybercrime reporting system. No verified campaign-wide loss, victim count or bank infrastructure breach is asserted. Prepared for academic and educational use, October 2026.

PRIMARY SOURCE [1]



Abstract

India’s expanding digital-banking and Unified Payments Interface (UPI) ecosystem has improved payment convenience while increasing exposure to social engineering. This case study analyses a phishing campaign documented by the Indian Computer Emergency Response Team (CERT-In) on 10 August 2021. Attackers used deceptive banking messages and counterfeit internet-banking websites exposed through the ngrok platform to obtain customers’ credentials, mobile numbers and one-time passwords. The captured information could enable unauthorised account access and fraudulent transactions without demonstrating a breach of the bank’s core systems.

The analysis examines the incident sequence, attack classification, root causes, potential impacts, detection opportunities and response priorities. It also connects the campaign’s manipulation techniques to UPI fraud prevention, while explicitly distinguishing this internet-banking incident from a confirmed UPI protocol exploit. Recommendations draw on CERT-In, Reserve Bank of India (RBI), National Payments Corporation of India (NPCI) and government reporting guidance. The study finds that authentication alone is insufficient when users are persuaded to surrender security information. Effective protection combines independent verification, clear payment authorisation, risk-sensitive monitoring, multilingual awareness and rapid reporting. No unverified loss figure or victim count is attributed to the campaign.

SOURCES [1–6]

184

WORDS IN ABSTRACT

Evidence-led analysis. No unsupported loss figures.

Introduction

Internet banking and UPI allow customers to transfer funds, pay merchants and manage accounts remotely. Their accessibility also gives criminals opportunities to impersonate familiar financial services. Instead of exploiting software directly, an attacker may exploit the customer's expectation that an urgent banking message deserves immediate action.

Phishing uses deceptive electronic communications; smishing delivers the lure through SMS, while vishing uses voice calls. Fake KYC requests combine a recognisable regulatory process with fear of losing account access. This report asks how the documented campaign crossed the customer–bank trust boundary and which safeguards could interrupt it. RBI and NPCI guidance provides the wider digital-payment context, rather than proof that every listed fraud technique occurred in this incident.

TRUST

IS NOT PROOF

Verify the bank through an independent channel.

SOURCES [1, 2, 4]

Incident description

CERT-In reported phishing websites targeting Indian banking customers through abuse of the ngrok platform. Messages directed recipients to counterfeit pages that resembled legitimate internet-banking portals. The uploaded report describes a KYC-related account-suspension lure: a plausible banking concern was used to pressure the recipient into opening a supplied link.

The fake page requested banking information, including credentials, a mobile number and OTPs. A customer could receive a genuine OTP after the attacker initiated activity with the real bank, then surrender that code to the counterfeit site. The advisory describes how harvested authentication information could support unauthorised access and fraudulent transactions. It does not establish a named victim's loss, an aggregate loss, or a technical compromise of UPI itself.

2021

DOCUMENTED CAMPAIGN

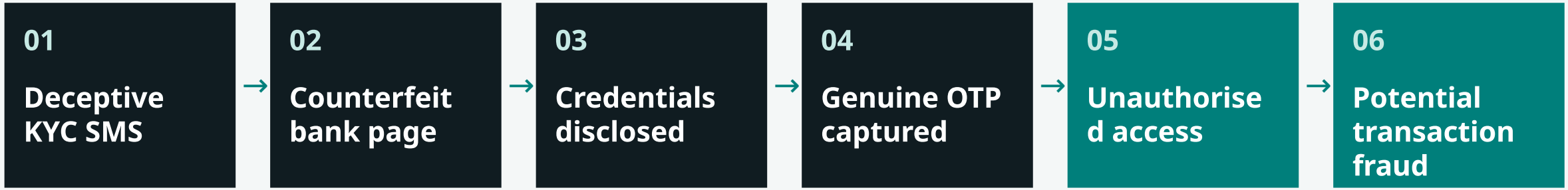
CERT-In advisory
CICA-2021-2948

SOURCES [1]

Anatomy of the attack

The diagram reconstructs the campaign's trust transitions, not an operational attack tutorial. First, a deceptive SMS brings an attacker-controlled destination into the customer's banking workflow. Second, a familiar-looking website encourages disclosure of the primary credentials. Third, the attacker can use those details against the genuine service, triggering an OTP delivered to the customer.

If the customer enters that OTP on the fake page, the additional authentication factor reaches the attacker rather than its intended recipient. Account access and attempted fraudulent transactions become possible. Each arrow marks an intervention point: independently verify the message, reject the counterfeit destination, protect the OTP, or detect the anomalous transaction. The illustration is an original synthesis of CERT-In's documented sequence.



Original reconstruction · not an incident screenshot · Source [1]

Attack type & vulnerability

This is primarily a social-engineering and credential-harvesting attack. Smishing delivers the lure; phishing supplies the imitation banking interface. Capturing a genuine OTP can defeat the practical protection of a second factor when that factor is disclosed in the wrong context.

The vulnerability is not evidence of broken encryption or a publicly identified bank software flaw. It lies in weak origin verification and the mistaken belief that a familiar design proves authenticity. Legitimate tunnelling infrastructure can also be abused to expose deceptive websites, but that does not make every ngrok link malicious. HTTPS indicates an encrypted connection; it does not prove that the destination belongs to a bank. No specific CVE or UPI protocol vulnerability is assigned.

OTP

CONTEXT MATTERS

A real code can be stolen by a fake site.

SOURCES [1]

Root cause analysis

The immediate cause is disclosure of authentication information to an attacker-controlled interface. The enabling human factor is urgency: a threat of account restriction can discourage careful verification. The process weakness is completing an unsolicited banking task through the message's link instead of independently opening the official service.

From a control perspective, passwords and transferable OTPs do not reliably communicate who receives the information or which action is being approved. Risk-sensitive transaction checks may offer another opportunity to intervene. These are analytical explanations, not verified findings from a bank's internal investigation. Blaming customers alone is inadequate; clear communication, usable verification, monitoring and rapid reporting must work together to reduce exposure.

VERIFY

BEFORE YOU ACT

Fear and urgency
can bypass judgement.

SOURCES [1, 2, 3]

Impact analysis

Financially, stolen authentication information can enable unauthorised transfers and attempted fund diversion. Confidentiality is threatened when banking identifiers, mobile numbers and authentication secrets are exposed. Integrity is threatened when an attacker can initiate account actions that the customer did not intend.

Other plausible consequences include distress, temporary account restrictions, investigation work and reduced trust in digital banking. Banks and payment providers may face support costs and reputational pressure. These are potential effects of the attack pattern, not measured outcomes established for this campaign. CERT-In's advisory does not provide a verified campaign-wide monetary loss or victim total. The absence of those figures is an evidence limitation, not proof that no harm occurred.

NO

VERIFIED LOSS TOTAL

Potential harms are not measured outcomes.

SOURCES [1]

Detection & response

Customers should question unexpected KYC demands, immediate suspension threats, unfamiliar destinations and requests for passwords or OTPs. Banks can correlate unusual devices, suspicious login activity, new beneficiaries and atypical transfer patterns. These monitoring controls are recommended opportunities, not confirmed detection events in the campaign.

After suspected fraud, contact the bank immediately through a verified channel and request protective action. Report financial cybercrime promptly through 1930 and the National Cybercrime Reporting Portal. Preserve the SMS, URL, timestamps, transaction identifiers and bank alerts. Reset exposed credentials through the official service. Reporting can support attempts to trace or hold funds, but recovery is not guaranteed. RBI liability rules depend on the circumstances and reporting timeline; quick reporting does not automatically guarantee zero liability.

1930

REPORT FINANCIAL FRAUD

Contact the bank.
Preserve the evidence.

SOURCES [3, 5, 6]

Security measures & mitigation

Customers should access banking through official applications or independently entered website addresses, verify unexpected requests, keep authentication secrets private and review transaction alerts. Updates and trusted application sources reduce exposure to related malicious-app risks, though no malicious-app stage is established here.

Banks should combine brand-impersonation monitoring, rapid phishing-site escalation, risk-sensitive authentication and transaction analytics. Clear alerts should identify the action being authorised. Payment providers should coordinate on suspicious activity and reporting pathways. Telecom operators, authorities and infrastructure providers can assist with malicious-link disruption and evidence preservation. RBI's digital-payment controls and awareness circular support layered prevention. Proposed safeguards should be proportionate, avoid unnecessary customer friction and be evaluated against real fraud outcomes rather than assumed effectiveness.



Illustrative cybersecurity image

SOURCES [2, 3, 4]

Why this matters for UPI

The selected incident concerns internet-banking impersonation; it is not evidence of a direct UPI protocol breach. Its relevance is the reuse of fear, trust and deceptive prompts across digital-payment channels. UPI scams may use misleading collect requests, fake refunds, malicious links or QR-code narratives to persuade users to authorise an unintended payment.

A UPI PIN authorises payment; it is not required merely to receive money. Customers should inspect the recipient and amount in their trusted payment application and reject unknown requests. OTPs used in account or device-related processes must also remain confidential. These UPI precautions come from broader safety guidance and must not be misrepresented as observed stages of the August 2021 campaign.



Illustrative cybersecurity image

SOURCES [2, 4]

Lessons learned

First, a genuine OTP does not make a fraudulent website genuine: authentication context matters. Second, visual resemblance and HTTPS cannot substitute for independent verification of a bank's identity. Third, security awareness should rehearse realistic decisions, particularly KYC pressure, instead of relying only on general warnings.

Fourth, fraud prevention must span the entire customer journey, from messages and links to beneficiary creation and payment approval. Fifth, fast reporting is a practical response priority, but institutions must make that reporting simple and accessible. Finally, academic analysis should preserve evidence boundaries. Distinguishing a documented phishing campaign from related UPI fraud patterns makes the conclusions more credible and avoids misleading claims about bank breaches, losses or technical vulnerabilities.

PAUSE

QUESTION THE REQUEST

Protect the customer's authorisation decision.

SOURCES [1–6]

Recommendations

Banks should provide a prominent, verified in-app route for checking KYC requests and reporting suspected fraud. They should rehearse phishing takedown escalation, review high-risk beneficiary activity and improve the clarity of authentication messages. Awareness programmes should use regional languages and test whether customers recognise deceptive approval requests.

Payment providers should make the payee, amount and payment direction easy to inspect before authorisation. Authorities, telecom operators and banks should strengthen coordinated threat sharing and preserve evidence for investigation. Customers should independently verify unexpected demands and report suspicious transactions immediately. Suggested evaluation measures include reporting delay, takedown time, false-positive rate and user comprehension. These are proposed indicators; no fabricated baseline, target reduction or campaign performance statistic is supplied.

ACT

WITH CLEAR OWNERSHIP

Measure response time and user comprehension.

SOURCES [2–6]

Conclusion & disclaimer

The August 2021 campaign illustrates how attackers can redirect trusted banking behaviour into credential and OTP disclosure. Its main lesson is that technical authentication needs independent verification, clear authorisation and layered monitoring. The same human-factors insight informs UPI safety without proving a UPI breach.

Disclaimer: This case study is for academic and educational purposes only. It adapts the uploaded report and uses public sources; analytical observations and diagrams are original synthesis, while generated cybersecurity images are illustrative, not incident screenshots. No real credentials or active malicious links are reproduced. It does not claim that every bank or UPI user was affected, or assign unsupported losses. Institutional approval and a plagiarism score have not been verified. It is not legal advice; use official channels for reporting.



Illustrative cybersecurity image

SOURCES [1–6]

References

[1] CERT-In · 10 August 2021 · CICA-2021-2948

Phishing websites hosted on NGROK platform, targeting Indian banking customers

Open official source ↗

[2] Reserve Bank of India · 22 June 2020

Increasing Instances of Payment Frauds – Enhancing Public Awareness Campaigns Through Multiple Channels

Open official source ↗

[3] Reserve Bank of India · 18 February 2021

Master Direction on Digital Payment Security Controls

Open official source ↗

[4] NPCI · Official digital-payment safety guidance

Fraud Awareness

Open official source ↗

[5] Government of India · I4C · Financial cybercrime reporting · 1930

National Cybercrime Reporting Portal

Open official source ↗

[6] Reserve Bank of India · 6 July 2017

Customer Protection – Limiting Liability of Customers in Unauthorised Electronic Banking Transactions

Open official source ↗

SOURCE NOTES

References support the documented incident, wider payment-fraud guidance, security controls and reporting advice. CERT-In is the primary campaign source; the other documents support contextual analysis and recommendations. Source numbers throughout the presentation refer to the entries below.

Prepared from the user-supplied Indian Banking Phishing UPI Fraud Case Study PDF, with original paraphrasing and an original flow infographic. Public-source research completed 8 October 2026. Online guidance may be updated; consult the linked official pages before taking action. Citation and paraphrasing reduce unsupported copying but do not certify a plagiarism percentage or satisfy an instructor’s approval process automatically. Confirm the selected campaign and any institution-specific disclaimer with your assessor before submission.